Vulnerability Assessment and Penetration Testing (VAPT) Report

- **Intern Name:** Tanisha Gupta
- **Internship Role:** Cyber Security Intern
- **Organization:** CyArt Tech
- **Task Title:** Vulnerability Assessment and Penetration Testing (VAPT)
- **Tools Used:** Kali Linux, Nmap, OpenVAS, Nikto, Metasploit Framework, OWASP ZAP
- **Target IP :** 192.168.207.129

1. Introduction

With the rapid advancement of technology today, organisations rely more heavily on information systems, networks and web applications to facilitate their operations. As organisations continue to depend on these technologies, they are seeing an increase in cyber related threats such as unauthorised access, data spills and vulnerabilities within systems. In order to help counter the threats that exist, organisations are required to implement preventative measures to identify and correct any weaknesses before they can be exploited. Vulnerability Assessment and Penetration Testing (VAPT) is a defined approach to cybersecurity used to understand, analyse and verify the security vulnerabilities that exist within systems, networks and applications. The Vulnerability Assessment component of VAPT is focused on identifying potential security weaknesses while Penetration Testing is used to determine the actual damage that could be done through the exploitation of those weaknesses if attacked by an individual or group that was performing those actions for malicious reasons.

The internship report for the VAPT domain at Cyart Tech will provide an overview of the practical experience and skills that I developed while partaking in a Cybersecurity related internship. The work that I carried out during my internship followed the standard VAPT processes which included conducting vulnerability scanning, analysing security risks and documenting the results of the scans and risk assessments with open source security tools. This report aims to communicate my understanding of the VAPT concepts, practical experience within the tools that were used during my internship, my identification of common vulnerability types, a basic risk analysis of the types of vulnerabilities that I was able to find and the professional documenting of the results in a way that satisfied both the organisation and industry security standards.

2. Understanding Security Assessment

Security assessment is the process of evaluating systems, networks, and applications to identify potential security weaknesses using open-source and non-proprietary tools. It helps in understanding the security posture of an organization and identifying areas that require improvement to reduce the risk of cyberattacks.

During the internship at **Cyart Tech**, security assessment activities were performed to analyze vulnerabilities, test system defenses, and understand how security gaps can be identified and mitigated in real-world environments.

➢ Types of Security Testing

- **Vulnerability Assessment**

Vulnerability Assessment focuses on identifying known security issues such as outdated software, open or misconfigured ports, weak system configurations, and missing security patches. Automated scanning tools like **OpenVAS** are used to detect vulnerabilities and generate detailed reports, including severity levels and CVSS scores.

- **Penetration Testing**

Penetration Testing involves simulating real-world cyberattacks to evaluate the exploitability of identified vulnerabilities. This process helps determine the potential impact of an attack on a system. Tools available in **Kali Linux**, such as **Nmap** for reconnaissance and **Metasploit Framework** for exploitation, are used to perform controlled penetration tests.

- **Compliance Testing**

Compliance Testing ensures that systems and security controls align with established security standards and regulatory requirements such as **ISO 27001**, **GDPR**, and **CIS Benchmarks**. This testing verifies whether security policies, configurations, and controls are implemented correctly to meet organizational and regulatory expectations.

3. VAPT Methodology

A structured methodology is essential to perform effective and systematic security testing. During the internship at **Cyart Tech**, the VAPT process was carried out by following standard industry practices to identify, analyze, and validate security vulnerabilities. The methodology ensures proper authorization, accurate results, and professional documentation. The VAPT process is divided into the following phases:

➢ Planning

The planning phase is the foundation of the VAPT process. In this phase, the scope of testing is clearly defined, including target IP addresses, applications, and testing limitations. Objectives such as identifying vulnerabilities, validating risks, and improving system security are established.

Rules of engagement are also defined to ensure that testing activities do not disrupt business operations or violate organizational policies. Proper authorization is obtained before starting the assessment. Documentation tools such as **Dradis CE** are used to manage project details, maintain scope clarity, and record initial observations throughout the assessment.

➢ Discovery

The discovery phase focuses on collecting detailed information about the target system to understand its attack surface. This phase includes **network scanning, service enumeration, and basic reconnaissance** to identify exposed services and system configurations.

Tools such as **Nmap** are used to discover active hosts, open ports, and running services, while **OWASP ZAP** is used for identifying potential web application vulnerabilities. The information gathered during this phase helps in identifying potential entry points and selecting suitable testing techniques for further analysis.

➢ Attack

In the attack phase, the vulnerabilities identified during the discovery phase are tested in a **controlled and ethical manner**. The goal is to determine whether these vulnerabilities can be exploited and to assess their potential impact on system confidentiality, integrity, and availability.

The **Metasploit Framework** is used to simulate real-world attack scenarios such as unauthorized access or service exploitation. Exploitation is performed only within the defined scope and environment to avoid any unintended damage. This phase helps in validating vulnerabilities and understanding the actual risk posed by them.

➢ Reporting

Reporting is the final and most critical phase of the VAPT process. In this phase, all findings are documented in a structured and professional format. The report includes details such as identified vulnerabilities, affected systems, severity levels, supporting evidence (screenshots or logs), and remediation recommendations.

Risk levels are assigned based on severity and potential impact to help prioritize mitigation efforts. The final report serves as a reference for improving system security and supports informed decision-making for implementing corrective actions.

4. Security Standards and Compliance

Security standards and compliance frameworks define how to secure sensitive data as well as how to maintain high levels of security. During my internship at Cyart Tech, I was familiar with these standards so our security assessments would be done in accordance to industry norms.

Examples of commonly used standards include GDPR (General Data Protection Regulation), which deals with privacy and overall protection of personal data, HIPAA (Health Insurance Portability Accountability Act), which provides requirements for security around health-related data, and ISO 27001 (International Organization for Standardization) provides an Information Security Management System (ISMS) framework that establishes and maintains information security throughout an organization. Compliance to these standards gives organizations a customizable framework to implement proper security controls and decrease risks associated with compliance.

Furthermore, OWASP Top 10 was used to provide a basis for driving the identification and prioritization of web application vulnerabilities that present the greatest risk. By aligning testing efforts with the OWASP Top 10, it was ensured that testing addressed and identified vulnerabilities that are most commonly exploited in alignment with established standards.

5. Risk Assessment Basics

Risk assessment is a crucial component of the Vulnerability Assessment and Penetration Testing (VAPT) process. It is used to analyze and prioritize identified vulnerabilities based on their severity, likelihood of exploitation, and potential impact on systems and data. Effective risk assessment helps organizations allocate resources efficiently and address the most critical security issues first.

During the internship at **Cyart Tech**, risk assessment was performed to evaluate the significance of discovered vulnerabilities and support informed decision-making for remediation planning.

➢ CVSS Scoring

The **Common Vulnerability Scoring System (CVSS)** is a standardized framework used to assign numerical severity scores to security vulnerabilities. CVSS evaluates vulnerabilities based on factors such as exploitability, attack complexity, required privileges, and impact on confidentiality, integrity, and availability.

CVSS scores range from **Low to Critical**, with higher scores representing greater risk. This scoring system provides a consistent and objective method for assessing vulnerability severity and comparing security risks across different systems.

➢ Risk Matrix

A **risk matrix** is used to classify vulnerabilities into **High, Medium, and Low** risk categories by assessing the likelihood of exploitation against the potential impact on the organization. This approach simplifies risk visualization and assists in prioritizing remediation efforts.

Vulnerabilities with high likelihood and high impact are categorized as high risk and require immediate attention, while medium and low risks are addressed based on organizational priorities. The risk matrix supports structured risk management and improves overall security decision-making.

6. Common Vulnerabilities

Identifying common vulnerabilities is an essential part of the VAPT process, as these weaknesses are frequently targeted by attackers. During the internship at **Cyart Tech**, both network-level and application-level vulnerabilities were studied and analyzed to understand their impact and mitigation methods.

➢ Network Vulnerabilities

Network vulnerabilities arise due to weaknesses in network configuration and security controls. Common examples include **open or unnecessary ports**, **weak authentication mechanisms**, **default credentials**, and **misconfigured services**. Such vulnerabilities increase the attack surface and can be exploited to gain unauthorized access to systems.

Tools such as **Nmap** are used to identify open ports, running services, and exposed network resources. Analyzing these findings helps in understanding network exposure and implementing appropriate security controls to reduce risk.

➢ Web Application Vulnerabilities

Web application vulnerabilities affect applications accessible over the internet or internal networks and can lead to serious security incidents. Common vulnerabilities include **SQL Injection (SQLi)** and **Cross-Site Scripting (XSS)**, which can result in data leakage, session hijacking, or unauthorized access.

To safely understand and practice the identification of such vulnerabilities, intentionally vulnerable platforms such as **OWASP Juice Shop** and **Metasploitable** are used in a controlled lab environment. These platforms provide hands-on experience in recognizing web application flaws and understanding their real-world impact without affecting live systems.

7. Documentation Fundamentals

Proper documentation is a critical component of the VAPT process, as it ensures that security findings are clearly communicated to technical teams and management. A well-structured security report helps in understanding identified vulnerabilities, associated risks, and recommended remediation actions.

During the internship at **Cyart Tech**, documentation focused on presenting findings in a clear, organized, and professional manner. Each report included vulnerability descriptions, supporting evidence such as screenshots or scan results, risk analysis, and practical remediation steps to improve system security.

➢ Tools Used for Documentation

The following tools were used to support effective documentation and reporting during the VAPT activities:

- **Dradis CE**: Used for collaborative reporting, organizing assessment data, and managing vulnerability findings in a structured format.
- **CherryTree**: Used for maintaining detailed technical notes, commands, observations, and intermediate findings during testing.
- **Microsoft Word / Google Docs**: Used for creating and formatting the final internship and VAPT reports for submission.

8. Practical Implementation

This section describes the practical VAPT activities performed during the internship, including environment setup, vulnerability scanning, documentation, and risk assessment. All testing was conducted in a controlled lab environment to ensure safety and authorization.

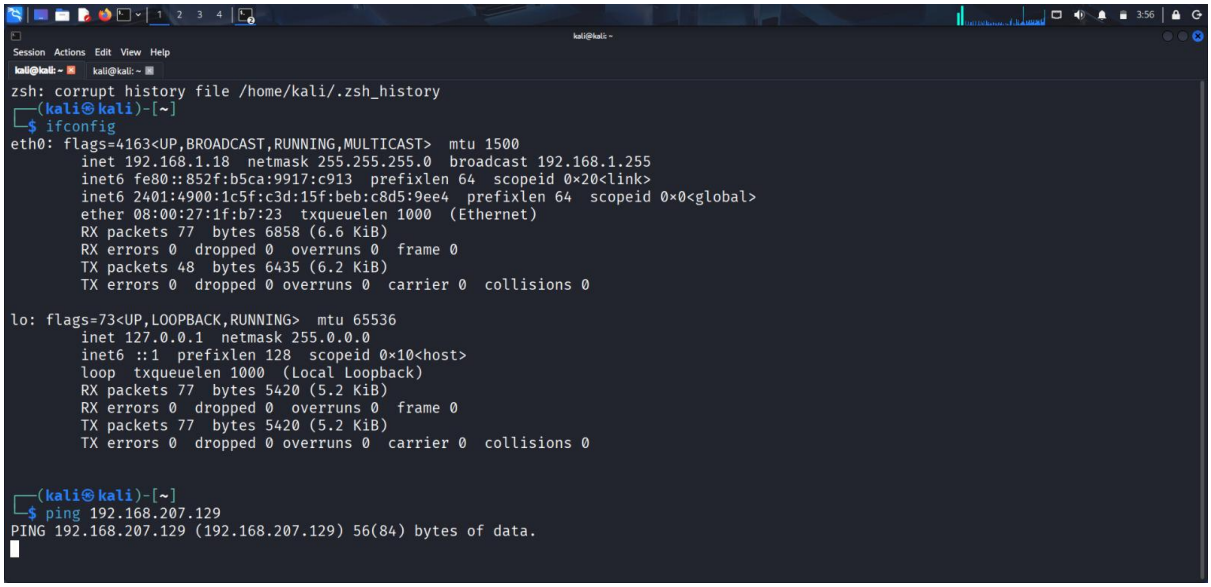
➢ Setup of Testing Environment

A secure testing environment was created using virtual machines to perform VAPT activities. **Kali Linux** was used as the attacker machine, while **Metasploitable** was used as the vulnerable target system. Both virtual machines were configured on the same internal network in **VirtualBox** to ensure proper communication and isolation from external networks.

Network connectivity between Kali Linux and Metasploitable was verified before starting the assessment to ensure successful scanning and testing.

Figure 1: Kali Linux virtual machine running in VirtualBox

Figure 2: Successful network connectivity between Kali Linux and Metasploitable

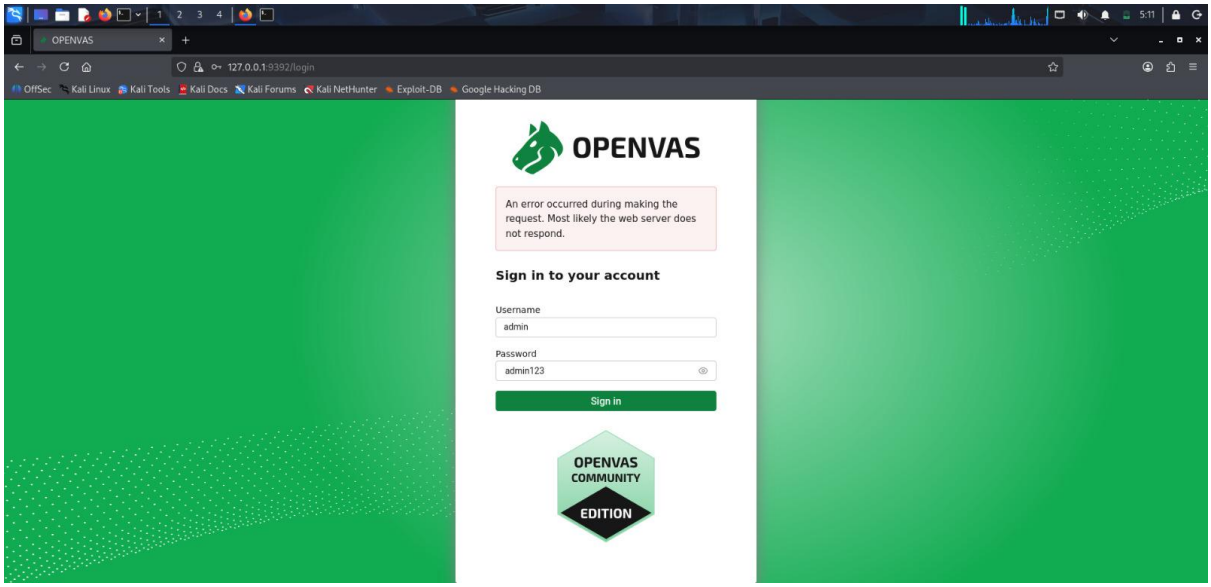


➢ Vulnerability Scanning

Vulnerability scanning was performed on the target system using **OpenVAS**, an open-source vulnerability assessment tool. The scan identified multiple security vulnerabilities along with their associated **CVSS scores** and **CVE identifiers**, helping to assess the severity of each issue.

Additionally, **Nikto** was used to identify web server–related vulnerabilities such as outdated components, insecure configurations, and missing security headers.

Figure 3: OpenVAS dashboard showing configured target



While attempting to sign in, an error message is displayed indicating that an error occurred during the request and the web server did not respond. This issue commonly occurs when OpenVAS backend services are not fully initialized, stopped, or temporarily unavailable.

Observation

- The OpenVAS Community Edition web interface is accessible.
- The login page is loaded successfully.
- An error message appears stating that the web server does not respond.
- This indicates a service-level or backend connectivity issue rather than incorrect login credentials.

Cause of the Issue

- The error occurred due to one or more of the following reasons:
- OpenVAS services were not fully started.
- Greenbone Vulnerability Manager (gvmd) or scanner services were inactive.
- Initial feed synchronization was incomplete.
- Temporary delay in service response after system startup.

Resolution / Troubleshooting Performed

To resolve this issue, the OpenVAS services were restarted using the following command in the Kali Linux terminal:

sudo gvm-start

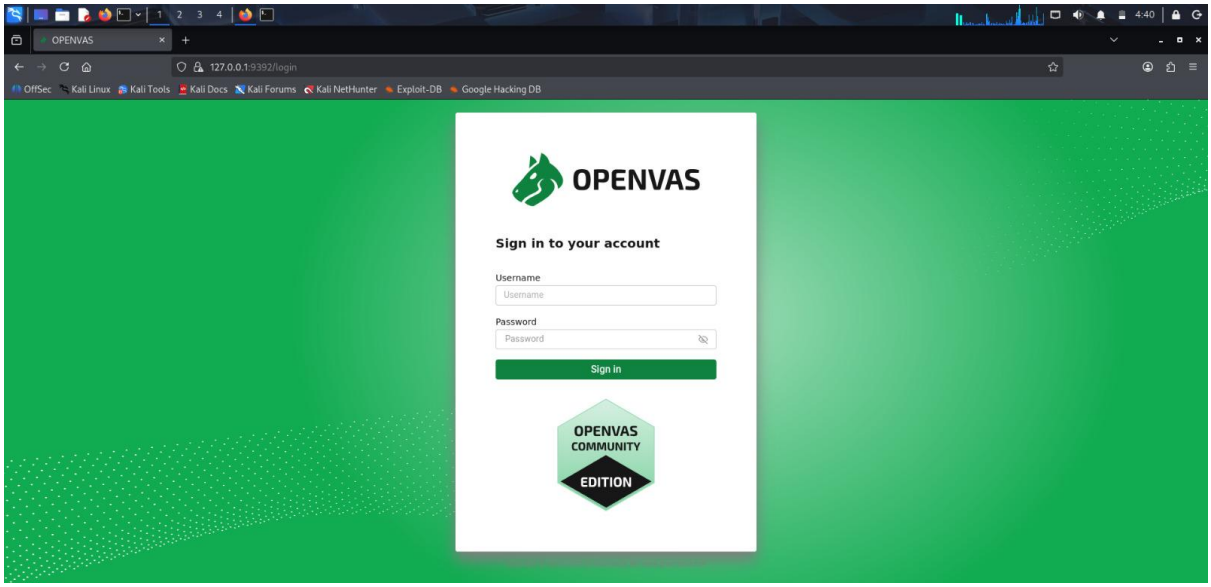
After restarting the services and allowing sufficient time for initialization, the OpenVAS web interface functioned correctly, and login was successful.

Outcome

Once the services were running properly, the user was able to log in to the OpenVAS dashboard, configure targets, and perform vulnerability scanning successfully.

Impact:

Temporary delay in vulnerability assessment due to service unavailability.



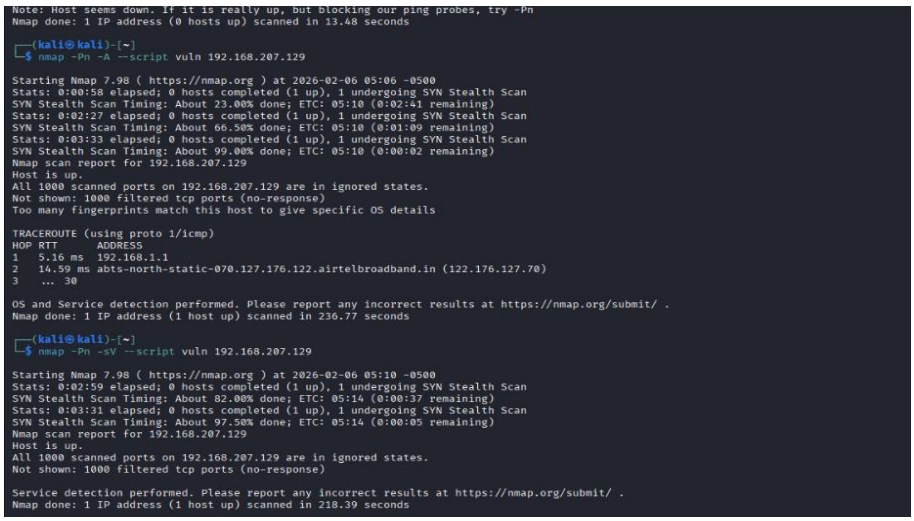
➢ Documentation of Findings

All identified vulnerabilities were documented in a structured and organized manner using spreadsheets. The documentation included details such as **IP address**, **port number**, **affected service**, **vulnerability description**, and **severity level**.

Screenshots of scan results and detected vulnerabilities were captured and included as supporting evidence to validate findings and enhance report clarity.

Figure 4: Vulnerability tracking sheet and Evidence screenshot of detected vulnerability

Since no open services were identified by nmap scan, **no CVSS scores were generated**,



```
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 13.48 seconds

┌──(kali㉿kali)-[~]
└─$ nmap -Pn -A --script vuln 192.168.207.129

Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-06 05:06 -0500
Stats: 0:00:58 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 23.00% done; ETC: 05:10 (0:02:41 remaining)
Stats: 0:02:27 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 66.50% done; ETC: 05:10 (0:01:09 remaining)
Stats: 0:03:33 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 99.00% done; ETC: 05:10 (0:00:02 remaining)
Nmap scan report for 192.168.207.129
Host is up.
All 1000 scanned ports on 192.168.207.129 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Too many fingerprints match this host to give specific OS details

TRACEROUTE (using proto 1/icmp)
HOP RTT      ADDRESS
1   5.16 ms  192.168.1.1
2   14.59 ms abts-north-static-070.127.176.122.airtelbroadband.in (122.176.127.70)
3   ... 30

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 236.77 seconds

┌──(kali㉿kali)-[~]
└─$ nmap -Pn -sV --script vuln 192.168.207.129

Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-06 05:10 -0500
Stats: 0:02:59 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 82.00% done; ETC: 05:14 (0:00:37 remaining)
Stats: 0:03:31 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 97.50% done; ETC: 05:14 (0:00:05 remaining)
Nmap scan report for 192.168.207.129
Host is up.
All 1000 scanned ports on 192.168.207.129 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 218.39 seconds
```

➢ Risk Assessment

Each identified vulnerability was evaluated using the **CVSS calculator** to determine its severity score. Based on the calculated score, vulnerabilities were categorized using a **likelihood versus impact risk matrix** to prioritize remediation efforts.

This approach helped in identifying high-risk vulnerabilities requiring immediate attention and supported effective decision-making for security improvements.

Figure 5: CVSS score calculation

Vulnerability	Service	CVE ID	CVSS Score	Severity
Backdoor Command Execution	FTP	CVE-2011-2523	10.0	Critical
Remote Code Execution	Samba	CVE-2007-2447	10.0	Critical
Apache Path Traversal	HTTP	CVE-2007-6203	7.5	High
Weak MySQL Auth	MySQL	CVE-2009-0819	6.5	Medium

Figure 6: Risk matrix showing vulnerability prioritization

The risk matrix helps visualize security posture and supports informed decision-making for future security improvements.

IP Address	Vulnerability	CVSS	Risk Level	Status
192.168.207.129	FTP Backdoor	10.0	Critical	Open
192.168.207.129	Samba RCE	10.0	Critical	Open
192.168.207.129	Apache Traversal	7.5	High	Open

9. Remediation Recommendations

Based on the findings of the Vulnerability Assessment and Penetration Testing (VAPT), the following remediation measures are recommended:

- Regularly apply security patches and software updates to fix known vulnerabilities.
- Disable unused services and remove unnecessary open ports to reduce the attack surface.
- Implement strong authentication mechanisms, including complex passwords and proper access controls.
- Enforce role-based access control to limit user privileges.
- Follow industry security best practices and compliance standards such as ISO 27001 and OWASP guidelines.
- Conduct periodic vulnerability assessments to identify and address new security risks.
- Maintain proper system monitoring and logging to detect suspicious activities.

10. Conclusion

Through my internship, I have gained real-world experience conducting a Vulnerability Assessment and Penetration Testing (VAPT) to learn about how security assessments function in a professional environment. This included systematic planning, discovery, vulnerability scanning, exploited testing and reporting. I learned to do these various phases of VAPT while using open-source tools such as Kali Linux, NMAP, OpenVAS, Nikto, Metasploit Framework, and OWASP ZAP. As a result, I improved my hands-on technical capabilities while becoming increasingly familiar with industry-relevant security tools.

The VAPT assessments revealed numerous security vulnerabilities within both the network and application layer of various systems. These findings indicated that conducting proactive security testing is essential to preventing potential cyber terrorism. By applying CVSS scoring and risk matrix techniques to evaluate vulnerabilities' severity and potential impact, I was able to prioritize vulnerabilities effectively. This structured approach assisted me in recognizing the need for timely remediation along with continuous monitoring to mitigate organisational security risk.

Additionally, my work during the internship highlighted the importance of maintaining adequate documentation and reporting throughout the entire VAPT process. Documentation of all findings in an accurate and well-organised manner, along with supporting evidence and appropriate remediations, facilitates effective communication between the security teams and their management.

11. References

- OWASP Foundation, OWASP Top 10 Web Application Security Risks
- National Institute of Standards and Technology (NIST), NIST Cybersecurity Framework
- National Vulnerability Database (NVD), CVSS Calculator
- Greenbone Security, OpenVAS Official Documentation